

Evil Twin, KARMA & MANA

Analiza ataków Rogue AP — metody detekcji i przeciwdziałanie

Piotr Straszak · Hubert Czernicki

Bezpieczeństwo bezprzewodowych sieci komputerowych

Agenda

01

Trzy typy ataków

Evil Twin → KARMA → MANA

02

Trzy metody detekcji

IE Fingerprinting · RSSI · Seq Numbers

03

Eksperymenty praktyczne

55 490 pakietów · 10 cykli ON/OFF

04

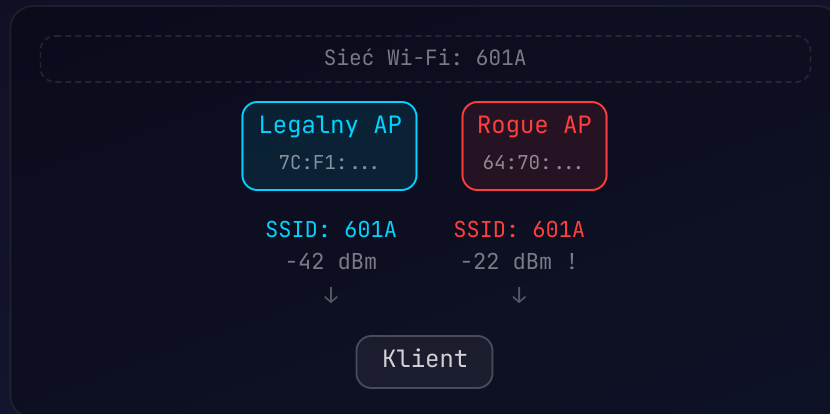
Mitygacja i wnioski

802.11w · WIDS · VPN · EAP-TLS

Czym jest Rogue Access Point?

- Nieautoryzowany AP podszywający się pod legalną sieć
- **Standard 802.11 nie weryfikuje tożsamości** AP
- Klient nie widzi różnicy między prawdziwym a fałszywym AP
- Konsekwencje: kradzież haseł, MITM, przechwycenie EAP

Zagrożenie: Captive portal, przechwycenie ruchu, atak na WPA2-Enterprise



Atak Evil Twin



MECHANIZM

1. Klonowanie SSID ofiary
2. Deauth → rozłączenie klienta
3. Silniejszy sygnał → auto-reconnect
4. Cały ruch przez atakującego

SYGNATURA W ETERZE

2 BSSIDs → 1 SSID
Delta RSSI = **20.3 dBm**
Różne Vendor OUI

Atak KARMA



Ofiara



KARMA AP

Probe: —————▶ "Starbucks?"
"Tak, jestem Starbucks!" ◀———— Beacon:
Probe: —————▶ "FreeWiFi?"
"Tak, jestem FreeWiFi!" ◀———— Beacon:
Assoc: —————▶ Association Request

✓ Ofiara złapana!

KLUCZOWE CECHY

- + Nie trzeba znać SSID z góry
- + Łapie **każdego** klienta w zasięgu
- + Brak deauth — atak pasywny
- iOS 10+ — skanowanie pasywne

SYGNATURA W ETERZE

1 BSSID → **wiele SSIDs**
RSSI = stałe (jedno urządzenie)
Brak ramek deauth

Atak MANA

SensePost · Defcon 22

ULEPSZENIA WZGLĘDEM KARMA

- **Directed Probe Response** — ignoruje docelowy BSSID
- **Loud Mode** — emituje 20+ popularnych SSIDs co ~10s
- **Multiple BSSID** — wirtualne AP z jednego interfejsu
- **EAP Capture** — przechwytuje handshake Enterprise

NARZĘDZIE

```
sudo apt install hostapd-mana  
hostapd-mana /etc/mana.conf
```

SKUTECZNOŚĆ VS KARMA

MANA odpowiada nawet gdy klient pyta **konkretny BSSID** — obchodzi zabezpieczenia iOS/Android

Porównanie trzech ataków

	Evil Twin	KARMA	MANA
Cel	1 konkretny SSID	Wszystkie probe requesty	Wszystkie + Loud Mode
Deauth	Tak (widoczny)	Nie (stealth)	Nie (stealth)
BSSID:SSID	Wiele → 1	1 → wiele	1 → wiele
Zna SSID?	Tak — musi znać	Nie — nasłuchuje	Nie + aktywne rozgłaszanie
Wykrycie	Łatwe (duplikat)	Średnie (anomalia SSID)	Średnie (loud beacons)
Skuteczność	Wysoka	Średnia	Wysoka

Evil Twin

Klonowanie KONKRETNEJ sieci

VS

KARMA / MANA

Łapanie KAŻDEGO klienta

Środowisko laboratoryjne

SPRZĘT

Element	Specyfikacja
System	Kali Linux ARM64, VMware
Karty Wi-Fi	2x TP-Link TL-WDN3200
Chipset	Ralink RT5572
AP ofiary	SSID: 601A
Ofiara	iPhone

NARZĘDZIA OFENSYWNE

`airgeddon` — Evil Twin + Captive Portal

`hostapd-mana` — KARMA i MANA

`WiFiSlayer` — Evil Twin framework

`airodump-ng` — przechwytywanie

NARZĘDZIA DEFENSYWNE (NASZE)

`analyze_pcap.py` — auto-detekcja

`beacon_diff.py` — porównanie IE

`Wireshark` — weryfikacja ręczna

Metoda 1 — Fingerprinting IE

Każdy AP ma unikalne **Information Elements** w ramce Beacon — jak odcisk palca sprzętu.

Liczba typów IE w ramkach Beacon



BRAKUJĄCE W EVIL TWIN

- HT Capabilities (LDPC, SGI, STBC)
- VHT Capabilities
- Power Constraint
- BSS Load
- AP Channel Report
- HT/VHT Operation
- Vendor Specific (Microsoft WPS)

Wynik: 14 z 17 IE się **różni**

Różny OUI vendora = **różne urządzenie**

Metoda 2 — Analiza RSSI

RSSI (Received Signal Strength Indicator) — atakujący zwykle umieszcza kartę **blisko ofiary**, dając nienaturalnie silny sygnał.

Średni RSSI [dBm] — bliżej 0 = silniejszy

-22.8
dBm



Evil Twin

-42.1
dBm



Oryginalny AP

Delta RSSI = 19.2 dBm

Próg anomalii: > 15 dBm

WYNIKI Z 6 EKSPERYMENTÓW

Delta min: 18.6 dBm

Delta max: 20.3 dBm

Delta avg: 19.5 dBm

Ograniczenie: doświadczony atakujący może dostosować moc nadawania (txpower)

Metoda 3 — Sequence Numbers

Każda karta Wi-Fi ma **12-bitowy sprzętowy licznik** (0–4095). Dwa urządzenia = dwa niezależne strumienie.



NAJSILNIEJSZA METODA

- + Niezależna od producenta
- + Nie da się zmanipulować (hardware)
- + Twardy dowód: 2 strumienie = 2 urządzenia

NASZE DANE

Evil Twin: 0 - 2045

Oryginalny: 0 - 4095

Overlap: brak nakładania

→ DWA urządzenia potwierdzone

Wyniki — Evil Twin

6810

Beaconów łącznie

2

Unikalne AP

19.2

Delta RSSI [dBm]

14/17

IE różnic

Ramki Beacon przechwycone

2928

Evil Twin

3882

Oryginalny

WSZYSTKIE 3 METODY POTWIERDZAJĄ

IE Fingerprinting: **różne OUI**

RSSI: anomalia **Delta = 19.2 dBm**

Seq Numbers: **2 niezależne strumienie**

EVIL TWIN CONFIRMED

Wyniki — KARMA i MANA

Anomalia: 1 BSSID nadaje wiele różnych SSIDów — to niemożliwe w normalnej sieci.

Beacony od BSSID 64:70:02:18:B9:22

FreeWiFi

267

601A

253

Starbucks

not seen

eduroam

not seen

KARMA — WYNIKI

iPhone wysyła probe requesty

KARMA odpowiada beaconem z żądanym SSID

Przechwycone: **601A** + **FreeWiFi**

MANA — WYNIKI

MANA AP uruchomiony — Tak

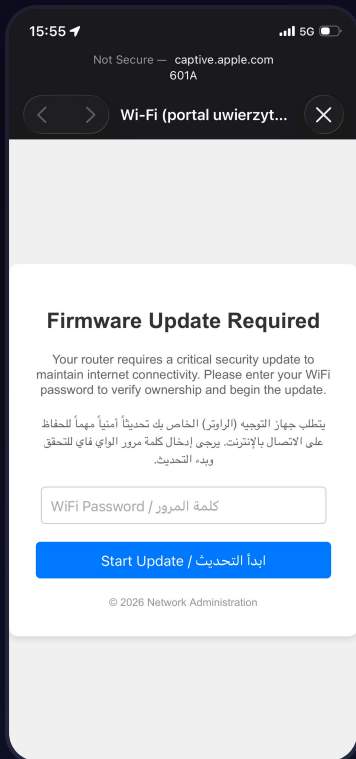
Directed probe przechwycony — Tak

Captive Portal na iOS — Nie (Apple CNA blokuje)

KARMA/MANA DETECTED

1 BSSID → wiele SSIDs = anomalia

Captive Portal — przechwycenie hasła



Captive portal na iPhone ofiary

SCENARIUSZ ATAKU

1. Evil Twin z captive portalem (WiFiSlayer)
2. Ofiara łączy się → fałszywy portal
3. „Firmware Update Required” — socjotechnika
4. Ofiara wpisuje hasło Wi-Fi

Przechwycone hasło:

mama1234

OK

DNS redirect
dnsmasq

55 490

pakietów w
10 cyklach

Eksperyment — 10 cykli ON/OFF

55 490

Pakietów

2 928

Beacony ET

10/10

Reconnect

~6s

Śr. czas

iPhone przechodzi między AP **automatycznie, bez wiedzy użytkownika** — w 10 próbach ani razu nie stwierdzono braku reconnectu.

PRZEBIEG EKSPERYMENTU

Cykl	Evil Twin	Reconnect	Czas
1-3	ON → OFF → ON	Tak	~5s
4-7	ON → OFF → ON	Tak	~6s
8-10	ON → OFF → ON	Tak	~7s

100% RECONNECT RATE

Atak działa za każdym razem

Mitygacja — jak się bronić?

ADMINISTRATORZY SIECI

802.11w (PMF)

Protected Management Frames — blokuje fałszywy deauth

WIDS / WIPS

Monitoring duplikatów SSID, anomalii RSSI, wzorców KARMA

EAP-TLS

Certyfikaty dla AP — klient weryfikuje tożsamość

UŻYTKOWNICY

VPN

Szyfruje ruch nawet na rogue AP — atakujący widzi „szum”

DNS-over-HTTPS

Ukrywa zapytania DNS przed przechwyceniem

Auto-join wyłączony

Nie łączy się automatycznie z sieciami Wi-Fi

Podsumowanie

3

Typy ataków

3

Metody detekcji

55K

Pakietów

100%

Reconnect

`analyze_pcap.py + beacon_diff.py` – open source (MIT)

github.com/Hose-Zur/BBSK-Evil-Twin

Pytania?